

Sổ Tay An Toàn Trí Tuệ Nhân Tạo & Phòng Thủ Prompt Injection

Tài liệu nghiên cứu kỹ thuật bảo mật ứng dụng LLM và hệ thống Retrieval-Augmented Generation.

1. Tổng Quan Về Tấn Công Prompt Injection

Tấn công Prompt Injection xảy ra khi kẻ tấn công chèn các câu lệnh điều khiển hệ thống vào trong dữ liệu người dùng (tệp PDF, văn bản tải lên) nhằm làm sai lệch hành vi của mô hình ngôn ngữ lớn (LLM).

2. Cơ Chế Phòng Thủ Đa Tầng Của KnowledgeOS

1. Cách ly Dữ liệu bằng Thẻ XML Tự Động: Lớp

`GroundedPromptBuilder` bọc toàn bộ nội dung trích xuất vào các thẻ XML `<evidence>` và chỉ định rõ đây là dữ liệu tham khảo, tuyệt đối không được coi là câu lệnh điều khiển.

2. **Chỉ Thị Nghiêm Ngặt Chống Ảo Giác:** Hệ thống bắt buộc AI từ chối trả lời nếu tài liệu không chứa đủ dữ liệu, loại bỏ hoàn toàn hiện tượng suy đoán vô căn cứ.

3. **Bảo Mật Bộ Nhớ Đệm và Phiên:** Mã hóa toàn bộ dữ liệu nhị phân trong bảng `storage_blobs` với cơ chế phân quyền `owner_id` tuyệt đối.